

BẢN ĐỒ ĐỌC CHAPTER 2

System architecture

**Tối ưu cho Reverse Engineering
và Malware Analysis**

23

trang đọc kỹ

14

trang chọn lọc

14

trang bỏ vòng đầu

Bản đồ toàn bộ 51 trang

Dùng số trang hiển thị trong trình đọc PDF. Không dùng số trang in của cuốn sách.



Lộ trình đọc chính



ƯU TIÊN SỐ 1

Trang 23-25: Ntdll.dll, Native API và system call. Đây là cầu nối trực tiếp giữa WinAPI, assembly và kernel - phần có giá trị nhất cho RE.

NGUYÊN TẮC

Không học thuộc danh sách. Mỗi mục chỉ cần: vai trò thành phần -> đường đi lời gọi -> dấu hiệu khi phân tích malware.

Cụm 1-3: nền tảng bắt buộc

Đọc theo đường đi của một lời gọi: chương trình -> WinAPI -> Ntdll -> syscall -> kernel.

TRANG

2-4

Kiến trúc user mode và kernel mode

- Phân biệt quyền và giới hạn của user mode với kernel mode.
- Nhận diện vai trò của subsystem DLL, Executive, Kernel, driver và HAL.
- Tự vẽ lại đường đi tổng quát từ chương trình đến tài nguyên hệ thống.

Liên hệ malware: Xác định payload đang ở user mode hay kernel mode; hiểu vì sao driver/rootkit có quyền mạnh hơn process thường.

TRANG

16-17

Subsystem DLL và ba kiểu xử lý WinAPI

- Biết Kernel32.dll, Advapi32.dll, User32.dll và Gdi32.dll là lớp API của Win32 subsystem.
- Phân biệt: xử lý hoàn toàn trong user mode; gọi system service; gửi ALPC đến subsystem process.
- Hiểu trường Subsystem trong PE header: GUI, Console hoặc Native.

Liên hệ malware: Không kết luận nhầm rằng mọi WinAPI đều tạo syscall; dùng Import Table và PE header để đoán hành vi mẫu.

TRANG

23-25

Ntdll.dll, Native API và system call - phần quan trọng nhất

- Đọc kỹ stub x64: mov r10, rcx; mov eax, service number; syscall; ret.
- Nhận diện Nt/Zw, Ldr, Rtl, Csr, DbgUi và Etw.
- Hiểu Native image chỉ phụ thuộc Ntdll.dll, ví dụ Smss.exe và Autochk.exe.
- Lăn được CreateFile/ReadFile từ WinAPI xuống NtCreateFile/NtReadFile.

Liên hệ malware: Là nền tảng của API hook, direct syscall, loader, unpacking, anti-debug, injection và EDR evasion.

CreateFileW -> KernelBase/Kernel32 -> NtCreateFile -> syscall -> Ntoskrnl

Cụm 4-5: hiểu ruột Windows để đọc tên hàm

Mục tiêu không phải thuộc lòng mọi component, mà là nhìn một API/hàm kernel rồi đoán đúng subsystem phụ trách.

TRANG

26-29

Executive, Kernel và các manager

- Lập bản đồ: Process Manager, Memory Manager, I/O Manager, SRM, Configuration Manager và Object Manager.
- Biết DeviceIoControl là cổng giao tiếp tổng quát từ user mode đến driver.
- Nắm khái niệm ALPC, handle/object, APC và DPC; chưa cần học cấu trúc sâu.

Liên hệ malware: Ảnh xạ hành vi malware vào đúng vùng: memory injection, token/security, registry persistence, file/device I/O.

TRANG

38-39

Interface không document và quy tắc tên hàm

- Xem export/import của Ntdll.dll, Ntoskrnl.exe và các subsystem DLL.
- Đọc tên theo mẫu <Prefix><Operation><Object>.
- Nhận diện Ps/Psp, Mm/Mi, Io/Iop, Ke/Ki, Ob/Obp, Se và Ex.

Liên hệ malware: Khi IDA không có source, prefix giúp đoán nhanh chức năng của hàm và chọn vùng code cần đào sâu.

Bảng prefix cần nhận diện

Prefix	Thành phần	Ví dụ / cách hiểu
Nt / Zw	Native system service	NtCreateFile, NtProtectVirtualMemory
Ps / Psp	Process và thread	PsCreateSystemThread
Mm / Mi	Memory manager	Mi thường là hàm nội bộ
Io / Iop	I/O manager	Iop thường là hàm nội bộ
Ke / Ki	Kernel primitives	thread, interrupt, dispatcher
Ob / Se / Ex	Object / Security / Executive	handle, token, pool, support

Cụm 6: process tree, service và persistence

Đây là baseline để phân biệt hành vi Windows bình thường với giả mạo process, injection và persistence.

TRANG

39-43

Các system process và quan hệ cha - con

- Biết vai trò của System, Smss.exe, Csrss.exe, Wininit.exe, Services.exe, Svchost.exe và Lsass.exe.
- Hiểu process trung gian có thể đã thoát nên process hợp lệ đôi khi không còn parent.
- Dùng parent, session, account, command line và module để kiểm tra tính hợp lý.

Liên hệ malware: Phát hiện process giả tên, parent bất thường, PPID spoofing, service payload hoặc code bị inject vào process hệ thống.

Baseline rút gọn

```
System
-> smss.exe
-> csrss.exe
-> wininit.exe
-> services.exe
-> svchost.exe
-> lsass.exe
-> winlogon.exe
-> userinit.exe
-> explorer.exe
```

Điểm cần kiểm tra khi phân tích

- Parent có đúng không?
- Process chạy ở session nào?
- Account là SYSTEM, service account hay user?
- Command line và đường dẫn file có hợp lý?
- DLL/module nào được nạp?
- Chữ ký số và thời điểm tạo process?

TRANG

46-50

Services, Winlogon và quá trình đăng nhập

- Services.exe quản lý service; Svchost.exe có thể host nhiều service/DLL.
- Winlogon -> LogonUI/Lsass -> Userinit -> Explorer tạo nên chuỗi đăng nhập cơ bản.
- Đọc kỹ vai trò của Lsass, token và Userinit/Shell trong registry.

Liên hệ malware: Giải thích được service persistence, DLL chạy trong Svchost, credential theft và thay đổi Winlogon Shell/Userinit.

ĐIỂM PERSISTENCE PHẢI GHI LẠI

BootExecute | SetupExecute | HKLM\SYSTEM\CurrentControlSet\Services | Winlogon\Userinit | Winlogon\Shell | KnownDlls

Đọc chọn lọc, bỏ qua và checklist

Những trang màu vàng chỉ cần lấy đúng ý bên dưới. Không sa vào lịch sử hay chi tiết triển khai chưa phục vụ mục tiêu hiện tại.

Trang	Chỉ lấy ý này	Khi nào học sâu
5	Tên các file lỗi trong Table 2-1; bỏ phần lịch sử portability.	Khi học Windows internals tổng quát.
13-15	VBS, VTL 0/VTL 1, securekernel.exe, Credential Guard.	Credential theft, kernel exploit, EDR bypass.
18-21	Vai trò Csrss.exe, Win32k.sys và Conhost.exe; bỏ chi tiết đồ họa.	GUI malware, console behavior, win32k exploit.
34-37	Driver .sys, file-system filter, software/filter driver, registry Services.	Reverse driver, rootkit, EDR/AV.
44-45	Chỉ nhật BootExecute, SetupExecute, KnownDlls và pending rename.	Boot persistence và forensic khởi động.

BỎ QUA Ở VÒNG ĐẦU

Trang 1, 6-12, 22, 30-33 và 51: design goals, SMP/NUMA, client-server SKU, WSL/Pico, KPCR/KPRCB, HAL chi tiết và kết luận. Quay lại khi học kernel debugging hoặc rootkit.

Checklist hoàn thành chapter

Kiến thức

- [] Vẽ lại WinAPI -> Ntdll -> syscall -> kernel.
- [] Giải thích Nt/Zw, Ldr, Rtl, Etw.
- [] Phân biệt Executive, Kernel và driver.
- [] Đọc được prefix hàm kernel.
- [] Nhớ vai trò các system process chính.

Thực hành

- [] Xem Subsystem và Import Table của một PE.
- [] Break tại ntdll!NtCreateFile trong WinDbg.
- [] Nhìn thấy mov eax + syscall trong stub x64.
- [] Dựng process tree bằng Process Monitor.
- [] Map Svchost.exe sang service/DLL bên trong.

ĐIỂM DỪNG HỢP LÝ

Khi làm được 5 mục kiến thức và 5 bài thực hành trên, coi như đã khai thác đủ Chapter 2 cho giai đoạn nhập môn RE và malware analysis. Phần kernel sâu để dành cho Chapter 3-8.